

Epics and User Stories — FlashID

Tech Titans · COS 301 Capstone 2026

This document contains all epics and user stories for the FlashID system, including acceptance criteria and definition of done for each story. See [SRS](#) for the full Software Requirements Specification.

3.2 Epics and User Stories

3.2.1 Epic 1: Identity Onboarding & Citizen Registration

US-1.1

As a Home Affairs official, I want to retrieve a citizen's verified identity record from the government registry, so that I can onboard them into FlashID using authoritative data.

Acceptance Criteria:

- Official can search for a citizen by SA ID number
- The SA ID number is checked for a valid 13-digit format and checksum before the registry is queried
- System queries the MockGov registry and returns the identity record if found
- System displays the citizen's full name, SA ID number and date of birth from the registry
- System shows a clear error if the SA ID is not found in the registry
- System rejects citizens younger than 16
- Official cannot proceed with onboarding until a verified record is retrieved

Definition of Done:

- Identity retrieval queries MockGov registry and returns authoritative data
 - Onboarding is written to the audit log
 - Duplicate SA ID numbers are rejected
-

US-1.2

As a Home Affairs official, I want to capture a citizen's explicit consent before creating their FlashID account, so that their data is processed lawfully under POPIA Section 11.

Acceptance Criteria:

- POPIA Section 11 notice is displayed to the official before consent is recorded
- Official must actively confirm consent, it cannot be pre-checked
- Consent record includes the official's ID, the citizen, and a precise timestamp
- System prevents onboarding from proceeding if consent has not been given
- Consent is recorded as an audit log entry

Definition of Done:

- Explicit POPIA consent is captured and stored with timestamp
 - Consent event is written to the audit log
-

US-1.3

As a Home Affairs official, I want to capture a citizen's contact details during onboarding, so that the citizen can receive their activation link.

Acceptance Criteria:

- Official must enter an email address for the citizen
- Official can optionally enter a South African mobile number
- Email is validated against standard email format rules
- Phone number is normalised to +27 format and validated as a South African mobile number
- Contact details are saved with the activation record before the activation link is sent

Definition of Done:

- Contact details saved and associated with the citizen's activation record
 - Invalid email or phone formats are rejected
-

US-1.4

As a Home Affairs official, I want the system to send an activation link to the citizen and give me an activation PIN after onboarding, so that the citizen can securely link their identity to their FlashID account.

Acceptance Criteria:

- System generates a unique activation link and a 6-digit activation PIN when onboarding succeeds
- The activation link is emailed to the citizen's captured email address
- The activation PIN is shown to the official once, to hand to the citizen in person
- The activation link and PIN expire after 48 hours
- Only hashes of the activation token and PIN are stored
- Wrong details lock activation for 5 minutes after 3 failed attempts and for 10 minutes after 5 failed attempts, the activation is revoked after 6 failed attempts

Definition of Done:

- Activation link generation and email delivery work end-to-end
 - Expired, used or revoked activations are rejected
-

US-1.5

As a citizen, I want to verify my identity using my SA ID number and a live selfie, so that I can activate my digital wallet without visiting a Home Affairs office.

Acceptance Criteria:

- A signed-in citizen can choose to verify with their physical ID instead of an activation code
- Citizen enters their SA ID number, which is checked against the MockGov registry
- Citizen completes an Azure Face liveness check that also compares their face with the registry portrait
- The citizen is linked to their FlashID account only if the registry match, liveness check and face match all pass
- Verification is blocked if the identity is already linked to another account
- A verification session expires after 15 minutes

Definition of Done:

- Liveness and face match integrated with Azure Face
 - Identity matched against MockGov before the citizen is linked to the account
-

US-1.6

As a citizen, I want to give explicit consent before my identity data is processed during physical ID verification, so that I understand and agree to how my personal information will be used.

Acceptance Criteria:

- A consent notice is displayed before any biometric processing starts
- Citizen must actively accept consent before continuing
- Consent timestamp is stored with the verification session
- The liveness check cannot start until consent has been recorded

Definition of Done:

- Consent captured and stored with timestamp before any biometric processing
-

US-1.7

As a citizen, I want to receive feedback when my identity verification fails, so that I know what went wrong and can take corrective action.

Acceptance Criteria:

- System shows a specific reason for failure: identity not found in the registry, liveness failed, face did not match the registry portrait, registry portrait unavailable, or identity already linked to another account
- Error messages are written in plain language
- The failure reason is stored on the verification session
- Citizen can start a new verification attempt

Definition of Done:

- All failure paths return a descriptive error message
-

US-1.8

As a citizen, I want to unlock the mobile app with my fingerprint or face, so that I can open my wallet securely without typing my password each time.

Acceptance Criteria:

- After the first successful sign-in on mobile, the citizen is offered biometric unlock
- Biometric unlock is optional and can be declined
- The device's own biometrics are used, with the device PIN as a fallback. Biometric data never leaves the device
- Biometric unlock can be turned on or off from the security settings sheet
- Viewing credential details and presenting a credential require biometric or device PIN confirmation

Definition of Done:

- Biometric unlock works on mobile using the device's hardware-backed authentication
-

3.2.2 Epic 2: Authentication & Role-Based Access Control

US-2.1

As a user, I want to sign in and see only the portal for my role, so that I cannot access another role's portal.

Acceptance Criteria:

- Users sign in with email and password
- A JWT is issued with a role claim of Citizen, Official or GovernmentAdministrator
- Users are redirected to their role's portal after sign-in
- Endpoints for other roles return an unauthorised error
- The mobile app supports Citizens and Officials, other roles see an unsupported-role screen
- The account is locked for 30 minutes after 5 failed sign-in attempts
- Sessions last 8 hours, or 30 days when "remember me" is selected

Definition of Done:

- JWT issued with correct role claims for all three roles
 - Role-based routing and endpoint authorisation enforced
-

US-2.2

As a citizen, I want to create a FlashID account with my email address and a password, so that I have an account to link my identity to.

Acceptance Criteria:

- Citizen registers with an email address and password
- Password must be at least 10 characters and include an uppercase letter, a lowercase letter, a digit and a special character
- System rejects an email address that is already registered

- A 6-digit code is emailed to verify the address, it expires after 10 minutes
- Verification is blocked after 5 wrong codes, and the citizen can request a new code
- Registration is logged to the audit trail

Definition of Done:

- Registration validates all input before creating the account
 - Email ownership verified by one-time code
-

US-2.3

As a user, I want to confirm new devices by email when I sign in, so that someone with my password cannot sign in from an unknown device.

Acceptance Criteria:

- Signing in from a device FlashID does not recognise sends a 6-digit code to the user's email
- The code expires after 10 minutes and the resend option is rate-limited
- A verified device is added to the user's trusted devices
- Device verification requests, failures, successes and resends are logged to the audit trail

Definition of Done:

- New-device sign-in requires email verification before a session is issued
-

3.2.3 Epic 3: Institution Registration & API Key Management

US-3.1

As a government administrator, I want to register an institution with the system, so that its officials can be linked to a verified institution.

Acceptance Criteria:

- Admin selects the institution type: Home Affairs, Licensing Department, Law Enforcement, Healthcare or Financial Institution
- Admin enters the institution name (up to 256 characters) and verification number (up to 100 characters)
- System rejects registration if the verification number already exists
- A random API key is generated on successful registration
- The API key is displayed exactly once and is never retrievable again
- Registration is logged to the audit trail with the admin's ID and timestamp

Definition of Done:

- Institution record created with type, verification number and registering admin
 - API key displayed once and not stored in plaintext
-

US-3.2

As a government administrator, I want to view all registered institutions, so that I can see which institutions are part of the system.

Acceptance Criteria:

- Admin can view a list of all registered institutions
- Each entry shows the institution name, type and verification number
- Admin can view full institution details
- An empty state is shown when there are no institutions

Definition of Done:

- Institution list loads with all required fields
-

US-3.4

As a government administrator, I want to search registered institutions, so that I can quickly find a specific institution.

Acceptance Criteria:

- A single search box matches institution name, type or verification number
- Matching is partial and case-insensitive
- An empty state is shown when no results match

Definition of Done:

- Search filters the list on name, type and verification number
-

3.2.4 Epic 4: Digital Credential Issuance

US-4.1

As an Official, I want to issue a digital driver's licence to a registered citizen, so that the citizen can use it for secure identity verification.

Acceptance Criteria:

- Official searches for the citizen by SA ID number before issuing
- Citizen must be Activated before a credential can be issued
- Official must record the citizen's POPIA consent before issuing
- Credential fields are sourced from the government registry
- System blocks issuance if the citizen already has an active credential of the same type
- The credential appears in the citizen's wallet and the citizen receives an in-app notification
- Consent and issuance are logged to the audit trail, failed issuance attempts are also logged

Definition of Done:

- Credential created from registry data and stored against the citizen

- Duplicate active credentials of the same type per citizen are blocked
-

US-4.2

As an Official, I want to look up a citizen by SA ID number before issuing a credential, so that I can confirm I am issuing to the correct person.

Acceptance Criteria:

- Search uses the full SA ID number
- Results show the citizen's name, SA ID, account status and existing credentials
- Official sees a clear error if no matching citizen is found
- Lookups are rate-limited and logged to the audit trail

Definition of Done:

- Search returns accurate results by SA ID
-

US-4.4

As a citizen, I want to be notified when a new credential is issued to my wallet, so that I am aware of all credentials issued in my name.

Acceptance Criteria:

- An in-app notification is created when a credential is issued
- The notification identifies the credential type that was issued

Definition of Done:

- In-app notification created on every successful issuance
-

US-4.5

As a citizen, I want to add my existing ID and driver's licence to my wallet after verifying my identity, so that I do not have to visit an office to get my digital credentials.

Acceptance Criteria:

- Only a verified citizen can activate credentials
- Citizen chooses which credential types to add: National ID, driver's licence, or both
- Credential data is fetched from the government registry
- Credential types the citizen already holds are skipped
- The citizen's status changes to Activated once at least one credential is added

Definition of Done:

- Selected credentials fetched from the registry and added to the wallet
-

3.2.5 Epic 5: Credential Wallet & Viewing

US-5.1

As a citizen, I want to view all credentials stored in my digital wallet, so that I can see what digital documents I have and their current status.

Acceptance Criteria:

- Wallet lists all credentials with credential type, issue date, expiry date (where applicable) and status
- Status is one of Active, Inactive, Investigation, Revoked or Expired, shown as a colour-coded badge
- An empty state is shown when no credentials have been issued
- The wallet shows the latest data each time it is opened

Definition of Done:

- Credential list shows all required fields
 - Status badge reflects the current credential status
-

US-5.2

As a citizen, I want to view the full details of an individual credential, so that I can confirm the information on my digital document is correct.

Acceptance Criteria:

- On mobile, the detail view requires biometric or device PIN confirmation before opening
- Detail view shows all credential fields, issue date and expiry date
- Current status is clearly displayed
- Citizen can navigate back to the credential list

Definition of Done:

- Mobile detail view secured behind biometric or device PIN confirmation
 - All credential fields rendered correctly for National ID and driver's licence
-

US-5.3

As a citizen, I want my credentials available on my phone without an internet connection, so that I can still present my identity in areas with poor connectivity.

Acceptance Criteria:

- Offline copies of active credentials are stored encrypted on the device, with the key held in secure storage
- Offline copies can be presented without internet (see Epic 13)
- Offline copies are refreshed when the device is online
- Offline copies are removed on sign-out

Definition of Done:

- Offline credentials load from the encrypted local cache without internet
-

3.2.6 Epic 6: QR Code Generation & Selective Disclosure

US-6.1

As a citizen, I want to generate a one-time QR code for a selected credential, so that an official can verify my identity.

Acceptance Criteria:

- Citizen selects a credential to generate a QR code from
- The QR contains a signed token (ES256) listing the credential reference and the disclosed field names, field values are not in the QR
- Generating a new QR invalidates any earlier QR for the same credential
- A QR can only be used once, a second scan is rejected
- QR cannot be generated for a credential that is not Active
- QR generation can be blocked by fraud detection (see US-11.9)

Definition of Done:

- QR token signed and one-time use enforced
-

US-6.2

As a citizen, I want to see how long my QR code remains valid, so that I know when to generate a new one.

Acceptance Criteria:

- The QR is valid for 60 seconds
- A live countdown is shown from the moment of generation
- The QR is replaced with an expired state when the countdown reaches zero
- An expired QR is rejected on scan
- Citizen can generate a new QR immediately after expiry

Definition of Done:

- QR expires after 60 seconds with a live countdown
 - Expired QR rejected on scan
-

US-6.3

As a citizen, I want to choose which fields from my credential are disclosed when I generate a QR code, so that I share only the minimum personal information needed.

Acceptance Criteria:

- Citizen can toggle optional fields on or off before generating the QR
- Mandatory fields cannot be deselected: date of birth and photograph for a National ID, photo, expiry date and date of birth for a driver's licence
- Requests with unknown fields or missing mandatory fields are rejected
- The verifier receives only the fields the citizen selected

Definition of Done:

- Selective disclosure enforces mandatory fields on the backend
-

US-6.4

As a citizen, I want to see exactly which fields will be visible to the verifier before confirming QR generation, so that I can make an informed disclosure decision.

Acceptance Criteria:

- On the web portal, a preview step lists every field that will be disclosed
- Citizen must confirm the preview before the QR is generated
- A back option returns the citizen to field selection

Definition of Done:

- Pre-generation preview lists all fields that will be disclosed
-

3.2.7 Epic 7: Cryptographic Security & Key Management

US-7.1

As a citizen, I want my QR tokens signed with a key the application cannot leak, so that a forged or altered token is detected.

Acceptance Criteria:

- QR tokens are signed with ES256 (ECDSA P-256)
- The signing key is held in Azure Key Vault and signing is performed by Key Vault
- The private key is never stored in the application database
- Each token records the key ID used to sign it

Definition of Done:

- Every QR token signed with the Key Vault key
 - Private keys never stored in the database
-

US-7.3

As an official, I want the signature checked on every QR scan, so that I can trust the result reflects the current state of the credential.

Acceptance Criteria:

- Signature verification runs on every scan, results are never cached
- A token whose contents have been altered fails verification
- The credential's current status is checked at scan time
- A token that has already been used is rejected

Definition of Done:

- Signature, expiry, one-time use and credential status checked on every scan
-

US-7.5

As a government administrator, I want the QR signing key rotated safely, so that a new key version can be introduced without downtime.

Acceptance Criteria:

- A daily job checks Azure Key Vault for a new version of the signing key
- When a new version is found, the previous signing key is marked Retired and the new one Active
- Each rotation run is recorded as a job run
- Offline verifiers download the current issuer public keys (see US-13.5)

Definition of Done:

- Key rotation job runs daily and records its result
-

3.2.8 Epic 8: Credential Verification

US-8.1

As an official, I want to scan a citizen's QR code to verify their credential in real time, so that I can confirm their identity without a physical document.

Acceptance Criteria:

- Official scans the QR code with the mobile app camera
- Screenshots are blocked on the scanning screen
- Result clearly shows whether the credential is valid
- A valid result shows the credential type and only the fields the citizen chose to disclose
- Scan attempts are rate-limited

Definition of Done:

- Verification result shown with only the disclosed fields
-

US-8.3

As an official, I want to see a clear result when a scan fails, so that I can take the correct action and inform the citizen.

Acceptance Criteria:

- A valid result shows a success indicator with the credential type and disclosed fields
- An invalid online scan shows a failure indicator with a plain-language message, expired, used, altered and inactive tokens are all reported as invalid
- Offline scans show a specific reason for each failure (see US-13.4)

Definition of Done:

- Every failed scan produces a clear, plain-language message
-

US-8.6

As an official, I want to see my verification history and activity stats, so that I can review the checks I have performed.

Acceptance Criteria:

- Official can view their history, filtered by search text, action, type and date range, with paging
- Official's home screen shows their activity stats and recent activity

Definition of Done:

- History and stats load for the signed-in official only
-

US-8.7

As an official, I want to show a digital badge, so that a citizen can see which institution I represent.

Acceptance Criteria:

- Official can display a signed badge QR identifying them and their institution
- The badge is valid for 60 seconds
- Badge verification returns the institution name, type and its suggested disclosure fields

Definition of Done:

- Badge token generated and verifiable by the backend
-

3.2.9 Epic 9: Credential Lifecycle Management

US-9.1

As a citizen, I want my digital credential to update automatically when my registry details change, so that it stays accurate.

Acceptance Criteria:

- A daily job compares every citizen's active credentials with the government registry
- Changed fields are updated in FlashID
- A government administrator can also trigger the check manually
- Updates and sync failures are logged to the audit trail
- Citizen receives an in-app notification when their details are updated

Definition of Done:

- Daily registry sync updates changed credentials and notifies the citizen
-

US-9.3

As a citizen, I want my driver's licence credential to change to Expired once it reaches its expiry date, so that expired credentials can no longer be used for verification.

Acceptance Criteria:

- A background job runs daily at 00:00 SAST to check expiry dates on Active driver's licence credentials
- Credentials past their expiry date are set to Expired
- QR verification rejects the credential immediately after the status change
- Expiry is logged to the audit trail
- Citizen receives an in-app notification when their credential expires
- If the daily run is missed, the check runs on the next service start-up
- A government administrator can trigger the check manually

Definition of Done:

- Expiry job runs on schedule, with start-up catch-up, and updates all due driver's licence credentials
 - Citizen receives an in-app notification on expiry
-

US-9.5

As a government administrator, I want to revoke a citizen's credential due to fraud, forgery or investigation, so that the credential can no longer be used for verification.

Acceptance Criteria:

- Admin must provide a reason before revocation is processed
- Revocation takes effect immediately. The next QR scan is rejected
- Revocation is logged to the audit trail with the admin's ID, reason and timestamp
- Citizen receives an in-app notification
- Admin can reinstate a revoked credential to Active with a reason, which is also logged and notified

Definition of Done:

- Revocation takes effect immediately
- Revocation and reinstatement reasons are required and logged

US-9.6

As a government administrator, I want to place a credential under investigation as a temporary status, so that I can stop its use without permanently revoking it.

Acceptance Criteria:

- Admin can set a credential's status to Investigation with a reason
- A credential under investigation is rejected on QR verification
- Admin can reinstate it to Active or revoke it
- Status changes are logged to the audit trail
- Citizen receives an in-app notification

Definition of Done:

- Investigation status prevents a valid verification result
- Admin can move a credential from Investigation to Active or Revoked

3.2.10 Epic 10: Audit Logging & POPIA Compliance

US-10.1

As a government administrator, I want the registration of an institution to be logged to the audit trail, so that there is a traceable record of every institution onboarded.

Acceptance Criteria:

- A log entry is created for every institution registration
- Log entry includes the admin's ID, institution name and timestamp
- Log entry is saved together with the institution record
- There is no endpoint to edit or delete audit log entries

Definition of Done:

- Institution registration always produces an audit log entry

US-10.2

As a Home Affairs official, I want a citizen's consent to be logged with a timestamp and my official ID, so that there is a verifiable record of consent for POPIA compliance.

Acceptance Criteria:

- A log entry is created when consent is captured during onboarding and during credential issuance
- Log entry includes the official's ID, the citizen, and a precise timestamp
- There is no endpoint to edit audit log entries

Definition of Done:

- Consent events logged with official ID and timestamp
-

US-10.4

As a government administrator, I want verification attempts to be logged, so that there is a record of credential verification events.

Acceptance Criteria:

- A log entry is created for every successful online verification, with the official's ID and credential reference
- Online tokens that fail signature or format checks are logged as failed verifications
- Offline verification results are uploaded and logged when the verifier reconnects (see US-13.6)

Definition of Done:

- Successful and forged verification attempts logged
-

US-10.5

As a government administrator, every revocation must be logged with reason, admin ID and timestamp, so that there is an accountable record of every credential revocation.

Acceptance Criteria:

- A log entry is created for every revocation and every change to Investigation
- Log entry includes the admin's ID, credential ID, new status, reason and timestamp
- Reinstatements are logged in the same way

Definition of Done:

- All revocation, investigation and reinstatement events logged with reason, admin ID and timestamp
-

US-10.6

As a government administrator, I want to search the audit log, so that I can investigate activity across the system.

Acceptance Criteria:

- Admin can view the audit log with paging
- Admin can filter by search text, action and date range

Definition of Done:

- Audit log viewer returns filtered, paged results to government administrators only
-

US-10.7

As a government administrator, I want a dashboard of system activity, so that I can monitor how FlashID is being used.

Acceptance Criteria:

- Dashboard shows system status, counts of users, institutions and credentials issued, and a recent activity feed
- Analytics show verifications, credentials issued, active officials and active institutions over a chosen date range, with daily figures and change since the previous period

Definition of Done:

- Dashboard and analytics load for government administrators only
-

3.2.11 Epic 11: Account Management & Device Security

US-11.1

As a citizen, I want to change my password from account settings, so that I can keep my account secure.

Acceptance Criteria:

- Citizen must enter their current password before a new one is accepted
- New password must be entered twice and both entries must match
- All sessions are signed out after the change, including the current one
- All trusted devices are removed, so each device must be verified again at next sign-in
- Password change requests are rate-limited

Definition of Done:

- Password change validates the current password and signs out all sessions
-

US-11.2

As a citizen, I want to reset my forgotten password by email, so that I can regain access to my wallet without contacting support.

Acceptance Criteria:

- Citizen requests a reset using their registered email address
- A 6-digit code is emailed and expires after 15 minutes
- The code is blocked after 5 wrong attempts
- New password must meet the complexity rules in US-2.2
- Reset requests are rate-limited
- Password reset is logged to the audit trail

Definition of Done:

- Password reset flow works end-to-end with expiry and rate limiting

US-11.3

As a citizen, I want to update my email address, so that notifications and security codes reach my current inbox.

Acceptance Criteria:

- Citizen must re-enter their password before requesting the change
- A 6-digit code is sent to the new email address and expires after 10 minutes
- The old address stays active until the code is confirmed
- Resends are limited and rate-limited
- Email change is logged to the audit trail

Definition of Done:

- Email changes require one-time code verification before taking effect
-

US-11.4

As a citizen, I want to delete my FlashID account, so that I can exercise my right to erasure under POPIA.

Acceptance Criteria:

- A signed-in citizen can delete their account
- Deletion removes the citizen's account, credentials, trusted devices and notifications
- Deletion takes effect immediately

Definition of Done:

- Account deletion removes all of the citizen's personal data
-

US-11.5

As a citizen, I want to view all devices that are trusted to access my FlashID account, so that I can identify any devices I no longer recognise.

Acceptance Criteria:

- Citizen can view a list of trusted devices with each device's name
- The current device is clearly marked

Definition of Done:

- Trusted device list shows all trusted devices and marks the current one
-

US-11.6

As a citizen, I want to remove a device I no longer trust, so that it must be verified again before it can sign in.

Acceptance Criteria:

- Citizen can remove any of their trusted devices
- A removed device must pass email device verification (US-2.3) at its next sign-in
- Citizens cannot remove another user's devices

Definition of Done:

- Removed device no longer appears in the trusted device list
-

US-11.9

As a citizen, I want FlashID to detect suspicious activity on my account, so that I am warned if someone else may be using it.

Acceptance Criteria:

- Sign-ins and QR generation are checked for suspicious patterns, including impossible travel (sign-ins from locations that would need travel faster than 900 km/h)
- Medium-risk and high-risk events create a security alert for the citizen
- A high-risk event blocks QR generation for 30 minutes
- Detected events and blocked QR attempts are logged to the audit trail

Definition of Done:

- Suspicious activity creates an alert, and high-risk activity restricts QR generation
-

US-11.10

As a citizen, I want to act on a security alert, so that I can either lock out an attacker or confirm the activity was mine.

Acceptance Criteria:

- Citizen can view their security overview, activity and alerts in the mobile app
- Securing the account requires the citizen's password, signs out all sessions, removes the suspicious device (or all other devices) and lifts the QR restriction
- Citizen can dismiss an alert that was their own activity, which lifts the QR restriction
- Securing and dismissing are logged to the audit trail

Definition of Done:

- Citizen can secure or dismiss an alert and the outcome is logged
-

US-11.11

As a citizen, I want to control my security settings, so that I can choose how strictly my account is monitored.

Acceptance Criteria:

- Citizen can turn impossible travel detection on or off
- Citizen can turn enhanced verification on or off
- Changing settings requires the citizen's password
- Settings changes are logged to the audit trail

Definition of Done:

- Security settings saved and applied to future fraud checks
-

3.2.12 Epic 12: Advanced Features & Certified Documents

US-12.1

As a citizen, I want to generate a certified copy of my credential as a downloadable PDF, so that I can use it for formal submissions that require a certified copy.

Acceptance Criteria:

- Certified copy can only be generated for an Active credential
- The PDF includes the credential fields and an embedded verification QR code
- A hash of the PDF and a snapshot of the credential are stored for later verification
- The certified copy is valid for 90 days

Definition of Done:

- Certified copy generated as a PDF with an embedded verification QR
 - Available only for Active credentials
-

US-12.2

As an official, I want to scan a citizen's emergency QR code to retrieve critical medical information, so that I can provide appropriate emergency care when the citizen cannot speak for themselves.

Acceptance Criteria:

- Only users with the Official role can resolve an emergency code
- The emergency code is signed by a key on the citizen's phone, is short-lived and can be used only once
- The official sees the citizen's chosen medical fields and emergency contacts
- Each access is logged with the official's ID, institution, timestamp and location (when provided), failed attempts are also logged
- The citizen and their emergency contacts are emailed when emergency access is used
- Emergency access also works offline and is uploaded when the official reconnects

Definition of Done:

- Emergency code returns only the citizen's emergency profile
 - Emergency access logged and contacts notified
-

US-12.3

As a citizen, I want to configure what my emergency QR shares, so that I control what emergency responders can see.

Acceptance Criteria:

- Citizen must consent before the emergency profile is enabled
- Citizen registers their phone to sign emergency codes
- Citizen chooses which medical fields to fill in: severe allergies, chronic medication, implanted devices, medical conditions, blood type, communication needs and medical aid details
- Citizen can add emergency contacts in priority order
- Profile changes are logged to the audit trail

Definition of Done:

- Citizen can configure the emergency profile and contacts
 - Consent recorded before the profile is enabled
-

US-12.4

As a person receiving a certified copy, I want to verify it online, so that I know the document is genuine and still valid.

Acceptance Criteria:

- Anyone can scan the QR on the PDF, or open its link, to see the verification result without signing in
- A PDF can be uploaded to check that it has not been altered
- The result shows whether the copy is valid, expired, or linked to a credential that is no longer active
- Verification requests are rate-limited

Definition of Done:

- Public verification page confirms authenticity and status of a certified copy
-

US-12.5

As a citizen, I want to see when my emergency profile was accessed, so that I know who viewed my medical information.

Acceptance Criteria:

- Citizen can view a list of emergency accesses to their profile
- Each entry shows who accessed it, their institution, when, the reason they gave, the location (when provided) and whether the access was offline

Definition of Done:

- Emergency access history visible to the citizen
-

3.2.13 Epic 13: Offline Verification

US-13.1

As a citizen, I want to show an offline QR code for my credential when I have no signal, so that I can prove my identity anywhere.

Acceptance Criteria:

- The share screen offers an offline code whenever an offline package is on the phone
- The citizen chooses which optional fields to share. Mandatory fields are always included
- Changing the shared fields while offline produces a new offline code
- A clear message is shown when no offline package is available yet

Definition of Done:

- Offline code shown for both identity documents and driver's licences with no network connection
 - Verified on two physical phones in aeroplane mode
-

US-13.2

As a citizen, I want my offline credentials prepared automatically while I am online, so that I do not have to remember to prepare them before losing signal.

Acceptance Criteria:

- Every active credential's offline package downloads when the citizen home screen loads online
- Packages are stored encrypted on the device and refreshed before they expire
- Signing out removes all offline packages from the device

Definition of Done:

- Packages available offline after one online visit to the home screen
 - Offline cache cleared on sign-out
-

US-13.3

As a citizen, I want my offline code to work only from my own phone, so that a screenshot or recording of it cannot be used to impersonate me.

Acceptance Criteria:

- Each offline credential is bound to a key created on the citizen's phone
- The phone re-signs the code every 5 seconds while it is shown
- A recording replayed after about 90 seconds, or a code copied to another phone, is refused
- Screenshots are blocked on the sharing screen

Definition of Done:

- Replayed recording refused on physical phones (device test protocol step 5)
 - A package request without the device key is refused by the backend
-

US-13.4

As an official, I want to verify a citizen's offline QR code without an internet connection, so that I can check identity in places with no signal.

Acceptance Criteria:

- The scanner collects the animated frames in any order and shows its progress
- The result shows the disclosed fields and the portrait, verified on the official's own phone
- Every failure shows a specific reason
- Scanning an online code without signal tells the official to ask for the offline code

Definition of Done:

- Offline verification works with both phones in aeroplane mode
 - Scan completes within 5 seconds for a driver's licence
-

US-13.5

As an official, I want revoked credentials to be refused even when I am offline, so that a revoked credential cannot be used where there is no signal.

Acceptance Criteria:

- The official's phone downloads a signed revocation list with the issuer keys while online
- The list is trusted only if its signature verifies
- A credential on the list is refused offline with "This credential has been revoked."
- The official is warned when verification data is over 24 hours old, and verification is refused when it is over 7 days old

Definition of Done:

- Revoked licence refused offline on physical phones (device test protocol step 6)
-

US-13.6

As a government administrator, I want scans made offline to appear in the audit log once the verifier reconnects, so that every verification remains accountable.

Acceptance Criteria:

- Offline results are kept on the verifier's phone and uploaded when it is online again
- Each scan is recorded once, however often the upload is retried
- Each record shows the verifier, the result, the phone's scan time and the server's receipt time
- Only verified scans are linked to the citizen's credential

Definition of Done:

- Offline scan visible in the audit log after reconnecting (device test protocol step 7)
-